GRC103 — Phishing Simulation Metrics and Quantitative Risk Analysis

Week 2 Practical Lab Report

Student Name: Imelda Sanya

Registration Number:C11/26/CGRCE/17576

1. Introduction

This report presents an analysis of three phishing simulation campaigns conducted at GlobalTech Inc. The aim was to assess how employees responded to different phishing scenarios, identify areas of concern and evaluate the potential financial impact of credential compromise.

The assessment also considers the cost of implementing security controls, particularly Multi-Factor Authentication (MFA), security awareness training and email filtering.

The analysis is based on the simulation results and organisational assumptions provided in Lab 3A. All calculations were independently reviewed, including the worked examples in the brief, as some of the original figures and assumptions required correction.

Excel calculations workbook: Open GlobalTech Phishing Risk Analysis Workbook

2. Phishing Simulation Results

The three campaigns targeted different employee groups using different approaches:

- Campaign A: HR Bonus Notification
- Campaign B: IT System Password Reset
- Campaign C: CEO Urgent Document Review

A total of 430 emails were sent across the three campaigns. Of these, 354 were opened, 257 links were clicked and 105 employees submitted credentials.

Metric	Campaign A	Campaign B	Campaign C
Emails sent	100	250	80
Emails opened	82	200	72
Links clicked	47	150	60
Credentials submitted	18	75	12
Personal data entries	5	25	8
Open rate	82%	80%	90%
Click-through rate	47%	60%	75%
Credential submission rate	18%	30%	15%
Data-entry rate	5%	10%	10%

2.1 Observations

Campaign C recorded the highest open rate at 90% and the highest click-through rate at 75%. This suggests that the CEO-themed message was particularly effective at attracting employees' attention and encouraging them to follow the link.

However, Campaign B recorded the highest credential submission rate at 30%. Out of the 150 employees who clicked the link, 75 proceeded to submit their credentials. This represents a 50% conversion rate from clicking to credential submission.

Campaign A recorded an 18% credential submission rate, with 18 employees submitting their credentials.

The results show that a high click-through rate does not necessarily translate into a high credential submission rate. Campaign C attracted more clicks proportionally, but Campaign B was more successful at obtaining credentials.

From a security perspective, Campaign B presents the greatest concern because of the number of credentials submitted and the proportion of employees who proceeded to disclose them after clicking the link.

3. Conversion Rate Analysis

In addition to calculating the overall campaign rates, I examined how employees progressed through the different stages of each phishing attempt. The open-to-click conversion rate measures the proportion of employees who clicked after opening the email. The click-to-credential conversion rate measures the proportion of those who clicked and subsequently submitted credentials.

Conversion metric	Campaign A	Campaign B	Campaign C
Open-to-click conversion	57.32%	75%	83.33%
Click-to-credential conversion	38.30%	50%	20%
Click-to-data-entry conversion	10.64%	16.67%	13.33%

Campaign B had the highest click-to-credential conversion rate at 50%. This means that one out of every two employees who clicked the link submitted their credentials.

This finding is particularly important because it shows that the risk does not end when an employee clicks a suspicious link. The subsequent actions taken on the landing page also determine the extent of exposure.

For this reason, monitoring credential submission and other information disclosure events provides a more useful indication of potential compromise than relying on click-through rates alone.

4. Organisational Risk Exposure

The next stage of the assessment involved estimating what the Campaign B results could mean if similar behaviour occurred across the organisation.

GlobalTech has 2,000 employees. Using Campaign B's credential submission rate of 30%, the projected number of employees who could submit credentials is:

2,000 × 30% = 600 employees.

The laboratory also provides an estimated 25% probability of a major breach if credentials are stolen. Applying this assumption to the projected 600 credential submissions gives:

600 × 25% = 150 expected events under the simplified model.

However, this calculation needs to be interpreted carefully. The result should not automatically be treated as 150 separate data breaches. Several compromised accounts could be involved in the same security incident, and the supplied information does not establish that each account creates an independent breach event.

4.1 Financial Exposure

The brief provides an estimated breach cost of $4.35 million. Applying this cost to the simplified projection gives:

150 × $4,350,000 = $652,500,000.

This produces an illustrative scenario exposure of $652.5 million.

It is important to distinguish this figure from an actual expected organisational loss. The calculation assumes that each projected event results in a separate breach costing $4.35 million. The supplied data does not establish that assumption.

The figure is therefore retained as a scenario calculation for comparison with the laboratory's worked examples, rather than presented as a confirmed financial liability.

4.2 Annualised Loss Expectancy (ALE)

Annualised Loss Expectancy (ALE) is calculated using:

ALE = Single Loss Expectancy (SLE) × Annual Rate of Occurrence (ARO).

The supplied breach cost of $4.35 million can be used as the scenario SLE. However, the brief does not provide a justified annual occurrence frequency.

The figure of 150 calculated earlier represents an expected value under the simplified model, not an established annual rate of occurrence.

For this reason, I have not treated $652.5 million as an annual ALE. A defensible annual loss estimate would require historical incident data or another justified estimate of how frequently the defined breach event could occur.

5. Security Control Cost-Benefit Analysis

Three security controls were considered: MFA, security awareness training and email filtering. The purpose of this assessment was to compare their implementation costs against the potential reduction in risk.

The effectiveness percentages provided in the laboratory brief have been treated as assumptions rather than guaranteed results.

5.1 Multi-Factor Authentication (MFA)

The proposed MFA implementation cost is $45 per employee. For 2,000 employees:

2,000 × $45 = $90,000.

The brief assumes that MFA would reduce credential theft impact by 99.9%. Using the illustrative $652.5 million exposure:

Gross risk reduction: $652,500,000 × 99.9% = $651,847,500.

Net benefit: $651,847,500 − $90,000 = $651,757,500.

ROI: ($651,757,500 ÷ $90,000) × 100 = 724,175%.

Although the calculated ROI is very high, it depends heavily on the effectiveness assumption and the underlying exposure estimate.

MFA remains a strong recommendation because it adds another layer of authentication and makes stolen passwords less useful to an attacker. However, its actual effectiveness will depend on how it is implemented and the authentication methods used.

5.2 Security Awareness Training

The proposed training cost is $50 per employee. For 2,000 employees:

2,000 × $50 = $100,000.

The brief assumes that training will reduce click-through rates by 60%. Campaign B's original click-through rate is 60%. Applying the assumed reduction:

60% × (1 − 0.60) = 24%.

The original click-to-credential conversion rate for Campaign B is 50%. Assuming this conversion rate remains unchanged after training:

24% × 50% = 12%.

The adjusted credential submission rate is therefore estimated at 12%.

Projected credential submissions: 2,000 × 12% = 240 employees.

Applying the supplied 25% probability assumption: 240 × 25% = 60 expected events under the simplified model.

Illustrative remaining exposure: 60 × $4,350,000 = $261,000,000.

Gross risk reduction: $652,500,000 − $261,000,000 = $391,500,000.

Net benefit: $391,500,000 − $100,000 = $391,400,000.

ROI: ($391,400,000 ÷ $100,000) × 100 = 391,400%.

One correction was necessary here. The original worked example used 30% as the starting click-through rate, whereas 30% is Campaign B's credential submission rate. The correct starting click-through rate is 60%. The adjusted credential submission rate of 12% is obtained by applying the reduced click-through rate to the observed 50% click-to-credential conversion rate.

Training should therefore be considered an important complementary control to technical measures such as MFA.

5.3 Email Filtering

The proposed email filtering investment is $50,000. The brief's worked example indicates a risk reduction of $130.5 million. This represents 20% of the illustrative $652.5 million exposure.

However, the brief does not explicitly provide a 20% effectiveness assumption. I have therefore treated this percentage as an inferred scenario assumption rather than a confirmed control effectiveness figure.

Before approving the investment, GlobalTech should evaluate the proposed email security solution against its ability to detect malicious links, impersonation attempts, suspicious attachments and spoofed messages.

5.4 Control Comparison

Control	Cost	Assumed effectiveness
MFA	$90,000	99.9% reduction in credential theft impact
Security awareness training	$100,000	60% reduction in click-through
Email filtering	$50,000	20% illustrative assumption

The ROI figures produced by the laboratory model are useful for demonstrating the calculation method, but they should not be used as confirmed financial returns. The three controls should also not have their individual risk reductions added together without accounting for overlapping benefits and interactions between them.

6. Risk Assessment and Prioritisation

Campaign	Main finding	Risk level	Recommended action
A	18% credential submission rate	High	Targeted security awareness training
B	30% credential submission rate and 75 credential submissions	Critical	Prioritise MFA and targeted training
C	75% click-through rate among executives and assistants	High	Executive-focused awareness and stronger identity controls

Campaign B is the highest priority because it recorded both the highest credential submission rate and the highest number of credential submissions. Campaign C also requires attention because of the high level of employee interaction with the phishing message, particularly among executives and assistants.

These ratings are provisional and should be reviewed against the organisation's approved risk-rating criteria.

7. Statistical Analysis

Confidence intervals were calculated to understand the uncertainty around the observed credential submission rates. The 95% confidence interval formula used was:

$CI = p \pm 1.96 \times \sqrt{[p(1 - p)/n]}$.

For Campaign A, the observed credential submission rate (p) is 0.18 and the number of emails sent (n) is 100. The margin of error is approximately 7.53%. The resulting confidence interval is approximately 10.47% to 25.53%.

Campaign	Observed rate	95% confidence interval
A	18%	10.47%–25.53%
B	30%	24.32%–35.68%
C	15%	7.18%–22.82%

The results indicate that Campaign B had the highest observed credential submission rate. The confidence intervals provide an indication of sampling uncertainty, but they do not guarantee that the same rates would apply across all employees.

The campaigns involved different target groups and sample sizes. In addition, the brief does not establish that the participants were randomly selected.

The workbook also includes Wilson confidence intervals for comparison, since the normal approximation used in the laboratory formula has limitations, particularly with smaller samples.

8. Modelling Limitations and Corrections

During the review, several issues were identified in the worked examples provided in the laboratory brief.

Financial exposure calculations

The Campaign A and Campaign C exposure figures in the brief contain arithmetic errors. Using the same simplified calculation:

- Campaign A: 18% × 2,000 × 25% × $4.35 million = $391.5 million.
- Campaign C: 15% × 2,000 × 25% × $4.35 million = $326.25 million.

These figures are mathematical outputs of the supplied scenario assumptions, not verified loss estimates.

Breach frequency

The projected 150 events cannot automatically be used as the annual rate of occurrence. An annual frequency must be supported by an appropriate event definition and evidence.

Independence of compromised accounts

The model assumes a relationship between compromised credentials and major breaches without explaining how separate accounts translate into separate incidents. This could significantly overstate financial exposure.

Control effectiveness

The MFA and training effectiveness figures were supplied as assumptions. The email filtering percentage was inferred from the worked example. All three require supporting evidence before they can be used in an actual business case.

Industry comparisons

The brief includes industry averages for credential theft, ALE and ROI but does not provide supporting references or explain how those figures were obtained. They have therefore not been used as verified benchmarks in this assessment.

These limitations are important because management decisions should be based on assumptions that can be explained and supported.

9. Recommendations

- Prioritise MFA implementation. Focus first on privileged accounts and employees with access to sensitive systems, followed by wider organisational rollout.
- Introduce targeted security awareness training. Training should address the specific techniques used in the simulations, including password-reset requests, financial incentives and executive impersonation.
- Review email security controls. Assess existing email filtering capabilities and identify opportunities to improve the detection of suspicious links, spoofed messages and malicious attachments.
- Review accounts involved in credential submission. In a real incident, these accounts should be assessed for potential compromise, with appropriate password resets, session revocation and authentication monitoring.
- Continue phishing simulations. Repeat the exercises periodically to establish whether employee behaviour improves following training and control implementation.
- Improve financial risk modelling. Collect incident history and establish a defensible annual breach occurrence frequency so that future ALE calculations are more meaningful.
- Monitor control effectiveness. Track credential submission rates, reporting rates, repeat susceptibility and suspicious authentication activity to measure whether the implemented controls are making a difference.

10. Conclusion

The three phishing simulations identified weaknesses in employee responses to phishing attempts, particularly where messages were designed around familiar organisational activities such as password resets and executive communications.

Campaign B presented the greatest concern because of its 30% credential submission rate. Campaign C also highlighted the effectiveness of executive-themed messages in encouraging employees to click suspicious links.

The results support investment in MFA, employee awareness and improved email security. However, the financial projections in the laboratory should be treated with caution because some of the

assumptions do not establish actual breach frequency or the number of independent security incidents.

The immediate priority should be to strengthen identity protection and address the employee behaviours identified in the simulations. Future assessments should then use actual incident data and measured control performance to improve the accuracy of the organisation's risk estimates.

Overall, the exercise shows the value of combining phishing simulation results with financial and statistical analysis when making security investment recommendations.